



Data Protection & AI Governance Self-Assessment

A working assessment of your organisation's readiness across data protection law — Egypt PDPL, EU GDPR, Saudi Arabia PDPL, UAE PDPL — and AI-specific governance under the EU AI Act, with a common-control crosswalk so multi-jurisdiction organisations get one assessment, not one per law.

LAW NO. 151 OF 2020 · EXECUTIVE REGULATIONS IN FORCE 2 NOV 2025 · COMPLIANCE DEADLINE 1 NOV 2026 · REGULATION (EU) 2016/679 · IN FORCE SINCE 25 MAY 2018 · ROYAL DECREE M/19 OF 2021, AMENDED M/148 OF 2023 · FULL ENFORCEMENT FROM 14 SEP 2024 · FEDERAL DECREE-LAW NO. 45 OF 2021 · FULL COMPLIANCE EXPECTED BY 1 JAN 2027 · EXCLUDES DIFC/ADGM (SEPARATE REGIMES) · REGULATION (EU) 2024/1689 · POST-DIGITAL OMNIBUS TIMELINE: ART. 50 TRANSPARENCY IN FORCE 2 AUG 2026 · ANNEX III HIGH-RISK 2 DEC 2027 · ANNEX I EMBEDDED SYSTEMS 2 AUG 2028 · 45 C.F.R. PARTS 160, 164 · PRIVACY RULE, SECURITY RULE, BREACH NOTIFICATION RULE · VOLUNTARY CERTIFIABLE STANDARD, EXTENDS ISO/IEC 27001 · NOT A BINDING LEGAL OBLIGATION · VOLUNTARY CERTIFIABLE STANDARD · NOT A BINDING LEGAL OBLIGATION · VOLUNTARY RISK-MANAGEMENT FRAMEWORK · NOT A BINDING LEGAL OBLIGATION

Client Information

Captured once per engagement — included on the generated report and saved with your progress file.

Organisation name	Assessment name	AI system assessed (optional)
ABC Co.	ABC Co.	RAG
Metadata only — tag this assessment to one named AI system when it's about a specific system rather than org-wide governance (relevant if EU AI Act / ISO 42001 is selected below). No live discovery, no per-system scoring.		
Industry / sector	Organisation size (employees)	Legal entities / subsidiaries in scope
Hospitality & Tourism	250–999	3
Primary contact	Contact email	Assessment date
ABC Co.	ABC Co.	25/08/2026
✓ Current — within the recommended 12-month re-assessment window.		

LEGAL JURISDICTION(S) — SELECT ONE OR MORE

- ☒ Egypt PDPL (Law 151/2020)
- ☒ EU GDPR (Regulation 2016/679)
- ☒ KSA PDPL (Royal Decree M/19)
- ☒ UAE PDPL (Decree-Law 45/2021)
- ☒ EU AI Act (Regulation 2024/1689)
- ☒ HIPAA (45 C.F.R. Parts 160, 164 — US healthcare sector only)

VOLUNTARY STANDARDS (OPTIONAL) — NOT A LEGAL OBLIGATION

- ☒ ISO/IEC 27701 (Privacy Information Management)
- ☒ ISO/IEC 42001 (AI Management System)

✔ **NIST Privacy Framework 1.0** (voluntary risk-management framework)

Currently assessing against: Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + EU AI Act + HIPAA + ISO 27701 + ISO 42001 + NIST Privacy Framework (125 questions across 26 modules)

SAVE OR RESUME THIS ASSESSMENT



Save progress (.json)



Load progress (.json)

How to use this register. Answer each clause as it applies to your organisation today, not as you intend it to be. Choose *Partial* where a control exists but is undocumented, inconsistent, or unverified. Your answers and the client information above stay in this browser tab only — nothing is transmitted anywhere — until you explicitly save a progress file or generate a report. This tool gives a directional maturity read; it is not legal advice and does not replace a formal audit. Selecting more than one regulation automatically merges equivalent questions into one harmonised item with combined citations — genuinely jurisdiction-specific questions stay individually badged rather than forced into a false common control. **On the EU AI Act module specifically:** this is a governance-readiness self-assessment only — it does not perform per-system risk-tier classification, does not constitute a conformity assessment, and is not a substitute for the accredited notified-body process required for high-risk systems.

DOMAIN I

Governance & Risk Management

Accountability structures, DPO appointment, and AI/automated-processing oversight.

\$ 01

Governance,
DPO & Foreign
Representation



Merged: Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + HIPAA + ISO 27701 + NIST Privacy Frame

Controllers and processors above the applicable threshold must appoint a qualified DPO and license their processing with the PDPC; foreign controllers processing Egyptian residents' data need a local representative. (Egypt PDPL: Art. 4, 8-9, 19-21, 32-33 | EU GDPR: Art. 5(2), 24, 27, 37-39 | KSA PDPL: PDPL (Royal Decree M/19, amended M/148) – Controller Registration & DPO provisions | UAE PDPL: UAE Federal Decree-Law 45/2021 – Art. 10-11 (DPO) | HIPAA: 45 C.F.R. §164.308 (Administrative Safeguards) | ISO 27701: ISO/IEC 27701 – Clause 5 (Leadership), 5.2 (PIMS scope) | NIST Privacy Framework: NIST Privacy Framework 1.0 – GV.PO-P (Governance Policies, Processes & Procedures))

Nearest framework cross-reference: ISO/IEC 27701 – Clause 5 (Leadership) & §6.15 (supplier relationships) · NIST Privacy Framework – GV.PO-P (Governance Policies, Processes & Procedures)

Q1 (Egypt PDPL Art. 8 · 2025 Exec. Reg. · EU GDPR Art. 37

HIGH RISK

· KSA PDPL DPO provisions · UAE PDPL Art. 10 · HIPAA

§164.308(a)(2), §164.530(a)) — We have appointed a Data Protection Officer (or equivalent responsible role) meeting the applicable qualification/registration bar in every selected jurisdiction.

✔ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + HIPAA)

EXAMPLE A retail group processing customer and employee data at scale appoints one DPO who is registered/qualified against each applicable jurisdiction's specific requirement.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

ABC Co.

Q2 (Egypt PDPL Art. 9 · EU GDPR Art. 38–39) — Our DPO is free from conflicting instructions, reports to senior management, and is not penalised for performing their duties.

MEDIUM RISK

✓ Harmonised (Egypt PDPL + EU GDPR)

EXAMPLE The DPO reports directly to the board, not to the Head of Marketing whose campaigns they oversee.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q3 (Egypt PDPL Art. 4 · 2025 Exec. Reg. · EU GDPR Art. 27) — If we are established outside this jurisdiction but process residents' personal data, we have appointed a local representative.

MEDIUM RISK

✓ Harmonised (Egypt PDPL + EU GDPR)

EXAMPLE An overseas head office receiving local customer data for group reporting has a named, accredited local representative.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q4 (Egypt PDPL Art. 8, 19–21 · KSA PDPL Registration requirements) — We are registered/licensed with the relevant data protection authority as required for our processing.

HIGH RISK

✓ Harmonised (Egypt PDPL + KSA PDPL)

EXAMPLE Your registration/licence reference is on file and its renewal date is tracked.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q5 (EU GDPR Art. 5(2) · KSA PDPL General compliance obligations · NIST Privacy Framework GV.PO-P1–P6) — We can demonstrate compliance — not just assert it — through documented policies, records, and training.

MEDIUM RISK

✓ Harmonised (EU GDPR + KSA PDPL + NIST Privacy Framework)

EXAMPLE An auditor asks 'prove you minimise data collection' and you can show a documented policy and evidence it's followed.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q6 (Art. 9) — Our DPO monitors compliance, trains staff, and can produce the required annual privacy protection report.

MEDIUM RISK

Egypt PDPL-only

EXAMPLE Your DPO can produce last year's privacy protection report on request, not just hold a title on an org chart.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q7 (Art. 8 · 2025 Exec. Reg.) — If we operate multiple legal entities, we've made a deliberate, documented choice between one group-level DPO and separate DPOs per entity.

MEDIUM RISK

Egypt PDPL-only

EXAMPLE A group with five subsidiaries has one PDPC-registered group DPO covering all of them, rather than an undocumented mix of informal local contacts.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q8 (Art. 8) — Our DPO's contact details are published and easy for data subjects and the PDPC to find.

LOW RISK

Egypt PDPL-only

EXAMPLE Your website's privacy page and your PDPC registration both list a current, working DPO contact — not a generic info@ inbox.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q9 (Art. 32–33) — We have a documented process to receive, log, and respond to PDPC inquiries or complaints.

LOW RISK

Egypt PDPL-only

EXAMPLE A complaint routed through the PDPC has a named internal owner, a response deadline, and a record of what was sent back.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q10 (Art. 11) — Our DPO's contact details are published and can be shared with the UAE Data Office on request.

MEDIUM RISK

UAE PDPL-only

EXAMPLE Your privacy notice and any regulator correspondence both list a current, working DPO contact.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q11 (General compliance obligations) — We can demonstrate compliance with PDPL obligations through documented policies, records, and training.

MEDIUM RISK

UAE PDPL-only

EXAMPLE An internal compliance file covers consent records, a data inventory, and breach response procedures.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q12 (§164.308 (a) (1) (ii) (A)) — We have conducted and documented a risk analysis identifying threats and vulnerabilities to electronic PHI (ePHI), and it's kept current as systems change.

HIGH RISK

HIPAA-only

EXAMPLE A risk analysis document lists specific systems holding ePHI and rates their exposure, and was last updated after the most recent system change — not written once at go-live and never revisited.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q13 (§164.308 (a) (1) (ii) (C)) — We have a documented sanctions policy for workforce members who violate HIPAA policies or procedures.

MEDIUM RISK

HIPAA-only

EXAMPLE A written policy specifies consequences for improperly accessing patient records, and there's a record it's actually been applied when needed.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q14 (§5.2) — The PIMS scope — which processing activities, systems, locations, and third parties it covers — is documented, approved by top management, and matches what's actually in production.

HIGH RISK

ISO 27701-only

EXAMPLE The documented scope names the specific business units and systems it covers, and someone has checked it still matches reality, not just what was true when it was written.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q15 (§5.3) — There is a named, accountable senior owner for the PIMS, with privacy responsibilities formally assigned rather than informally assumed.

MEDIUM RISK

ISO 27701-only

EXAMPLE An org chart or RACI names who owns PIMS performance, distinct from who happens to answer privacy questions day to day.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q16 (§5.2.3) — The organisation has determined and documented whether it acts as a PII controller, PII processor, or both, for each major processing activity.

MEDIUM RISK

ISO 27701-only

EXAMPLE Your data inventory tags each processing activity with its controller/processor role, since obligations differ materially between the two.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q17 (GV.PO-P4) — Privacy roles and responsibilities are coordinated with internal and external stakeholders (legal, security, HR, vendors) rather than owned in isolation by one function.

MEDIUM RISK

NIST Privacy Framework-only

EXAMPLE Privacy, security, and legal teams have a defined coordination point for cross-cutting decisions, rather than each operating from a separate, uncoordinated policy.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

S 02

AI & Automated Processing Governance

Merged: Egypt PDPL + EU GDPR + EU AI Act + ISO 42001

The 2025 Executive Regulations require safeguards where personal data is used to train, fine-tune, or evaluate AI/ML models — against bias, unauthorized disclosure, and infringement of data subject rights. (Egypt PDPL: Art. 4 · 2025 Exec. Reg. | EU GDPR: Art. 22, 35 | EU AI Act: Regulation (EU) 2024/1689 — Art. 22, 27 | ISO 42001: ISO/IEC 42001 — Clause 4.1-4.3 (AIMS scope), Annex A.6.2)

Nearest framework cross-reference: ISO/IEC 27701 — §7.2 (tangential — see ISO/IEC 42001 instead) · NIST Privacy Framework — NIST AI RMF (Govern/Map/Measure/Manage) rather than core Privacy Framework

Q18 (Egypt PDPL 2025 Exec. Reg. · EU GDPR Art. 22 · EU AI Act Recitals 27, 61; Art. 10) — Where personal data is used to train, fine-tune, or drive automated decisions, we apply safeguards against bias, unauthorized disclosure, and infringement of data subject rights.

HIGH RISK

✓ Harmonised (Egypt PDPL + EU GDPR + EU AI Act)

EXAMPLE A recommendation engine trained on customer history is checked for demographic bias and can't be prompted to reveal an individual's raw data.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q19 (Egypt PDPL Art. 4 · 2025 Exec. Reg. · EU GDPR Art. 35 · EU AI Act Art. 27 (FRIA) · ISO 42001 Clause 4.3, Annex A.6.2) — We maintain an inventory of AI/ML systems that consume personal data, each with a documented risk/impact assessment.

MEDIUM RISK

✓ Harmonised (Egypt PDPL + EU GDPR + EU AI Act + ISO 42001)

EXAMPLE A single register lists your lead-scoring model and your ad-targeting model, each with a documented safeguard review.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q20 (Annex A.6.2) — For each AI system, the intended purpose, prohibited uses, target users, affected groups, and operating environment are documented.

MEDIUM RISK

ISO 42001-only

EXAMPLE

A hiring-screening tool's documentation states what it's meant to do, what it must not be used for, and who it affects.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

§ 03

Governance Structure & Ownership (RACI)

Merged: Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL

Appointing a DPO (covered in Governance above) is necessary but not sufficient — day-to-day privacy work touches HR, IT, marketing, and procurement, and someone needs a documented answer for who is Responsible, Accountable, Consulted, and Informed on each of those fronts, not just who holds the DPO title. (Egypt PDPL: General data-governance expectation | EU GDPR: GDPR Art. 24 (Responsibility of the Controller) | KSA PDPL: General data-governance expectation | UAE PDPL: UAE Federal Decree-Law 45/2021 — general governance expectation)

Nearest framework cross-reference: ISO/IEC 27701 — · NIST Privacy Framework — ·

Q21 (Egypt PDPL General data-governance expectation · EU GDPR Art. 24 · KSA PDPL General data-governance expectation · UAE PDPL General governance expectation) —

LOW RISK

A documented governance structure (a RACI matrix, a Privacy Champion network, or equivalent) assigns privacy responsibility across departments beyond the DPO alone, and is actually referenced when questions or incidents arise — not just filed away.

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL)

EXAMPLE

When marketing wants to launch a new data-driven campaign, there's a documented owner in marketing who is expected to loop in the DPO — not an assumption that 'the DPO will catch it somehow'.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Data Lifecycle & Inventory

Knowing what data exists, why it's held, and how long it's kept.

\$ 04

Data Inventory & Records of Processing (RoPA)

Merged: Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + ISO 27701 + NIST Privacy Framework

Controllers must maintain processing records open to PDPC inspection, linking every category of data to a purpose, lawful basis, and retention period. (Egypt PDPL: Art. 4 | EU GDPR: Art. 5(1)(c), 30 | KSA PDPL: PDPL – data inventory/classification expectations | UAE PDPL: Art. 7(4), 8(7) | ISO 27701: ISO/IEC 27701 – §5.2.2, 7.2.8 (Records of processing) | NIST Privacy Framework: NIST Privacy Framework 1.0 – ID.IM-P (Inventory & Mapping))

Nearest framework cross-reference: ISO/IEC 27701 – §7.2.8 (Records of processing activities) · NIST Privacy Framework – ID.IM-P (Inventory & Mapping)

Q22 (Egypt PDPL Art. 4 · EU GDPR Art. 30 · KSA PDPL Data classification · UAE PDPL Art. 7(4), 8(7) · ISO 27701 §5.2.2 · NIST Privacy Framework ID.IM-P1-P8)

HIGH RISK

— We maintain a Record of Processing Activities / data inventory covering purposes, data categories, recipients, and retention.

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + ISO 27701 + NIST Privacy Framework)

EXAMPLE A single register lists every processing activity across HR, marketing, and product, each with a documented purpose and retention period.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q23 (Art. 4)

MEDIUM RISK

— We can estimate, with reasonable accuracy, how many personal data records we hold across all systems.

Egypt PDPL-only

This figure typically feeds directly into PDPC licence fee tiers.

EXAMPLE You could tell a regulator roughly how many customer, employee, and lead records exist across your CRM, HR system, and marketing lists.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

file:///Users/user/Library/CloudStorage/OneDrive-FixedSolutions 2/Products_Projects/-Products/EU AI Act compliance/Egypt-PDPL-self-assessment-v2_14.html 9/47

Q24 (Art. 4, 6) — We maintain an inventory of every system and storage location holding personal data, including on-premise servers and cloud/SaaS platforms.

MEDIUM RISK

Egypt PDPL-only

EXAMPLE A single list shows that bookings sit in an on-prem server, HR data sits in a cloud HR platform, and marketing leads sit in a third-party CRM.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q25 (Art. 1, 13–14) — We know which of our data flows involve special categories (biometric, financial, health, criminal record) and flag them differently in our inventory.

MEDIUM RISK

Egypt PDPL-only

EXAMPLE Spa health questionnaires and access-control fingerprints are flagged in the inventory as sensitive, not lumped in with general contact details.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q26 (Art. 5(1)(c)) — We collect only the personal data that is adequate, relevant, and limited to what's necessary for the stated purpose.

MEDIUM RISK

EU GDPR-only

EXAMPLE A newsletter sign-up form collects an email address only, not a full postal address 'for future use.'

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q27 (§5.2.1) — Applicable privacy laws, regulations, contractual obligations, and sector-specific requirements relevant to the organisation's processing have been identified and documented.

MEDIUM RISK

ISO 27701-only

EXAMPLE A single register lists every law/regulation/contract clause that constrains how a given data category can be processed.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q28 (ID.DE-P) — Data processing is mapped end-to-end, including data flows to and from third parties, so the organisation understands its full processing ecosystem.

MEDIUM RISK

NIST Privacy Framework-only

EXAMPLE A data-flow diagram traces a customer record from initial collection through every internal system and external vendor it touches.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

\$ 05

Data

Merged: Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + ISO 27701 + NIST Privacy Framework

Accuracy,
Retention &
Minimisation

Data may only be collected for specified purposes, must be kept accurate and up to date, and retained no longer than necessary. (Egypt PDPL: Art. 2, 3, 6 | EU GDPR: Art. 5(1)(d), 5(1)(e), 16 | KSA PDPL: PDPL — purpose limitation & retention provisions | UAE PDPL: General data-quality & retention provisions | ISO 27701: ISO/IEC 27701 — §7.4 (Privacy by design/default), 7.2.5 (Retention) | NIST Privacy Framework: NIST Privacy Framework 1.0 — CT.DP-P (Disassociated Processing))

Nearest framework cross-reference: ISO/IEC 27701 — §7.4.7 / §7.2.5 (Retention & minimisation) · NIST Privacy Framework — CT.DP-P (Disassociated Processing — data minimisation)

Q29 (Egypt PDPL Art. 3 · EU GDPR Art. 5(1)(e) · KSA PDPL Retention provisions · UAE PDPL Retention provisions · ISO 27701 §7.4.7) — We have documented retention periods per data category and a process to delete or anonymise data once they expire.

MEDIUM RISK

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + ISO 27701)

EXAMPLE CVs of unsuccessful applicants are deleted or anonymised after a defined period, not kept indefinitely.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q30 (Egypt PDPL Art. 2, 3 · EU GDPR Art. 5(1)(d), 16 · UAE PDPL Data accuracy provisions · ISO 27701 §7.4) — We take reasonable steps to keep personal data accurate and up to date, correcting or erasing it when it isn't.

MEDIUM RISK

✓ Harmonised (Egypt PDPL + EU GDPR + UAE PDPL + ISO 27701)

EXAMPLE A customer who updates their phone number in one system has it corrected everywhere that number is used.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q31 (Art. 3) — We collect only the data strictly necessary for a stated, legitimate purpose.

MEDIUM RISK

Egypt PDPL-only

EXAMPLE A newsletter sign-up form asks for an email address only, not date of birth and phone number 'just in case.'

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q32 (Art. 3, 6) — New systems and products are designed with retention limits built in from the start, not bolted on afterwards.

LOW RISK

Egypt PDPL-only

The 2025 Regulations push toward a 'design-based' rather than purely outcome-based model.

EXAMPLE A new booking platform is built with an automatic deletion rule for guest data, rather than adding one years later.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q33 (Art. 3) — Where data is kept beyond its original purpose (e.g. for statistics), it is anonymised so individuals can no longer be identified.

MEDIUM RISK

Egypt PDPL-only

EXAMPLE Historical booking data used for trend reporting has names and contact details stripped out.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q34 (CT.DP-P1-P5) — We evaluate and apply de-identification, aggregation, or other disassociation techniques to reduce identifiability where the processing purpose doesn't require individual-level data.

MEDIUM RISK

NIST Privacy Framework-only

EXAMPLE An analytics use case that only needs aggregate trends is built on de-identified data rather than raw, individually identifiable records.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

\$ 06

Data Classification Scheme

Merged: Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL

Flagging sensitive fields inside the RoPA (covered in Data Inventory above) is different from having a formal, multi-tier classification scheme applied consistently across every system — the latter is what actually drives differentiated access controls, encryption requirements, and retention rules at scale. (Egypt PDPL: Art. 1, 13-14 · 2025 Exec. Reg. | EU GDPR: GDPR Art. 9, 32 | KSA PDPL: PDPL – data classification expectations | UAE PDPL: UAE Federal Decree-Law 45/2021 – data classification expectations)

Nearest framework cross-reference: ISO/IEC 27701 – · NIST Privacy Framework –

Q35 (Egypt PDPL Art. 1, 13-14 · EU GDPR Art. 9, 32 · KSA PDPL PDPL – data classification · UAE PDPL Data classification expectations) — We use a documented, multi-tier data classification scheme (e.g. Public / Internal / Confidential / Restricted) applied consistently across systems and data stores — not an informal, case-by-case judgment call.

LOW RISK

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL)

EXAMPLE Every system in the inventory carries one of four defined tiers, each with its own minimum security and access-control baseline.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q36 (Egypt PDPL General data-governance expectation · EU GDPR General data-governance expectation · KSA PDPL General data-governance expectation · UAE PDPL General data-governance expectation) — Classification tags are kept current as new systems or data sources are added, rather than only assigned once at initial rollout.

LOW RISK

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL)

EXAMPLE A new system is tagged against the classification scheme as part of its launch checklist, not discovered untagged during a later audit.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

§ 07

Training, Testing & Validation Data Governance

Merged: EU AI Act + ISO 42001

High-risk AI training/testing/validation datasets must meet quality criteria — relevance, representativeness, freedom from errors, and appropriate examination for possible bias. (EU AI Act: Art. 10 | ISO 42001: ISO/IEC 42001 — Annex A.7)

Nearest framework cross-reference: ISO/IEC 27701 — §7.2.8 (loose parallel — records of processing) · NIST Privacy Framework — NIST AI RMF — MAP 2 (data/context mapping)

Q37 (EU AI Act Art. 10 · ISO 42001 Annex A.7.2) — We document the provenance of datasets used to train, test, and validate AI systems, and confirm we're authorised to use the data for that purpose.

HIGH RISK

✓ Harmonised (EU AI Act + ISO 42001)

EXAMPLE A dataset's documentation records where the data came from, how representative it is, and confirms licensing/consent covers this specific AI use.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q38 (EU AI Act Art. 10(2)(f)–(g) · ISO 42001 Annex A.7.3–A.7.4) — Training data is evaluated for quality, representativeness, and bias, with datasets version-controlled so a given output can be traced back to the data/model version that produced it.

MEDIUM RISK

✓ Harmonised (EU AI Act + ISO 42001)

EXAMPLE A hiring model's training data is checked for historical bias, and the exact dataset/model version behind a specific decision can be identified after the fact.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

§ 08

Technical Documentation & Record-Keeping

Merged: EU AI Act + ISO 42001

Providers of high-risk AI must maintain technical documentation before market placement and ensure automatic logging capability throughout the system's lifecycle. (EU AI Act: Art. 11–12 | ISO 42001: ISO/IEC 42001 — Annex A.4, Clause 7.5)

Nearest framework cross-reference: ISO/IEC 27701 — Not applicable — outside PIMS scope · NIST Privacy Framework — NIST AI RMF — GOVERN 1.2 / MAP 4 (documentation)

Q39 (EU AI Act Art. 11, Annex IV · ISO 42001 Annex A.4, Clause 7.5) — Technical documentation for each AI system — intended purpose, design specifications, and performance metrics — is maintained before the system is placed in production.

MEDIUM RISK

✓ Harmonised (EU AI Act + ISO 42001)

EXAMPLE A single documentation package per system covers its intended purpose, architecture, and validation results, ready for internal or external review.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q40 (EU AI Act Art. 12 · ISO 42001 Annex A.4) — The organisation can reconstruct, from records, who approved a given AI system's deployment and what material changes have occurred across its lifecycle.

MEDIUM RISK

✓ Harmonised (EU AI Act + ISO 42001)

EXAMPLE An auditor asking 'who approved this model going live, and what's changed since' gets a documented answer, not institutional memory.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

§ 09

Documentation Retention

HIPAA

Policies, procedures, risk analyses, training records, BAAs, and other HIPAA-related documentation must be retained for six years from creation or last effective date, whichever is later. (45 C.F.R. §164.530(j) (Documentation Retention))

Nearest framework cross-reference: ISO/IEC 27701 — · NIST Privacy Framework —

Q41 (§164.530(j)(2)) — HIPAA-related documentation (policies, risk analyses, training records, BAAs, breach assessments) is retained for at least six years from creation or last effective date.

MEDIUM RISK

EXAMPLE A records-retention schedule specifically calls out the six-year HIPAA documentation requirement, distinct from other, shorter retention schedules the organisation may use elsewhere.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Lawful Processing & Consent

The legal basis for processing, and extra protections for sensitive and children's data.

§ 10

Lawful Basis & Consent

Merged: Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + ISO 27701 + NIST Privacy Framework

Processing requires explicit, informed consent unless another lawful basis applies; consent must be documented and freely given. (Egypt PDPL: Art. 2, 3, 4 | EU GDPR: Art. 6, 7 | KSA PDPL: PDPL – consent as the default lawful basis | UAE PDPL: Consent & lawful basis provisions | ISO 27701: ISO/IEC 27701 – §7.2 (Conditions for collection & processing) | NIST Privacy Framework: NIST Privacy Framework 1.0 – CT.PO-P (Data Processing Policies))

Nearest framework cross-reference: ISO/IEC 27701 – §7.2 (Conditions for collection & processing) · NIST Privacy Framework – CT.PO-P (Data Processing Policies)

Q42 (Egypt PDPL Art. 3, 4 · EU GDPR Art. 6 · KSA PDPL Consent provisions · UAE PDPL Consent provisions) — We can point to a documented lawful basis (consent or a specific statutory exception) for every processing activity.

HIGH RISK

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL)

EXAMPLE You can explain why HR keeps payroll records versus why the CRM keeps browsing history — for every system, not just the obvious ones.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q43 (Egypt PDPL Art. 2 · EU GDPR Art. 7 · KSA PDPL Consent withdrawal · UAE PDPL Consent withdrawal) — Consent can be withdrawn as easily as it was given, and we act on withdrawal promptly.

MEDIUM RISK

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL)

EXAMPLE A guest who agreed to marketing emails can click 'unsubscribe' and stops receiving messages within days, not weeks.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q44 (Art. 4 · 2025 Exec. Reg.) — We obtain explicit, informed consent before collecting or processing personal data.

HIGH RISK

Egypt PDPL-only

Consent must be specific, freely given, and evidenced — not bundled into generic terms of use.

EXAMPLE A booking site has a clear, unticked checkbox for marketing emails, separate from the checkbox confirming the reservation itself.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q45 (Art. 3) — Where we rely on "implied consent" for a requested service, that use is narrowly limited to delivering that service.

MEDIUM RISK

Egypt PDPL-only

A common failure mode is stretching implied consent to cover marketing or profiling.

EXAMPLE Using a guest's room number to deliver a requested room-service order is fine; reusing it to build a marketing profile is not, without separate consent.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q46 (§5.4, 7.2) — Privacy risk assessments are performed before new processing begins or changes materially, and explicitly consider necessity and proportionality, not only security exposure.

HIGH RISK

ISO 27701-only

EXAMPLE A new processing proposal is assessed for whether it's proportionate to its purpose before approval, not just checked for security controls.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q47 (§5.4) — High-risk processing activities are escalated for senior approval before they proceed.

MEDIUM RISK

ISO 27701-only

EXAMPLE A proposed large-scale profiling activity is escalated to the PIMS owner for sign-off rather than proceeding on the project team's own authority.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q48 (CT.PO-P1) — Data processing policies define, and constrain processing to, the specific purposes for which data was collected.

HIGH RISK

NIST Privacy Framework-only

EXAMPLE A policy prevents a dataset collected for support-ticket handling from being repurposed for marketing analytics without a fresh review.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q49 (CT.PO-P3) — Data processing permissions (who/what system can process which data, for which purpose) are actively managed, not left as broad, unreviewed default access.

MEDIUM RISK

NIST Privacy Framework-only

EXAMPLE Access to a sensitive dataset is scoped to the specific team performing the approved purpose, reviewed periodically rather than granted once and forgotten.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

S 11

Sensitive Personal Data

Merged: Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL

Health, financial, biometric, genetic, religious, and similar data require explicit written consent and a specialized PDPC permit. (Egypt PDPL: Art. 1, 13–14 | EU GDPR: Art. 9 | KSA PDPL: PDPL – sensitive data provisions | UAE PDPL: Sensitive data provisions)

Nearest framework cross-reference: ISO/IEC 27701 – §7.2.2 (Special categories of PII) · NIST Privacy Framework – CT.DP-P (Disassociated Processing)

Q50 (Egypt PDPL Art. 1, 13–14 · EU GDPR Art. 9 · KSA PDPL Sensitive data provisions · UAE PDPL Sensitive data provisions) — We separately identify sensitive/special-category personal data and apply enhanced controls and consent to it.

HIGH RISK

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL)

EXAMPLE An employee's health-insurance claim or biometric access data is tagged, access-restricted, and encrypted differently from general records.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q51 (Art. 3) — Sensitive data is processed only for narrowly defined, documented purposes — never as a by-product of general processing.

MEDIUM RISK

Egypt PDPL-only

EXAMPLE Fingerprint data collected for building access control is not later reused to build a customer loyalty profile without a fresh legal basis.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q52 (Art. 13–14) — Where our processing of sensitive data requires it, we hold the specialized PDPC permit for that processing.

HIGH RISK

Egypt PDPL-only

This permit is distinct from the general controller/processor licence.

EXAMPLE A clinic processing patient health records holds the specific sensitive-data permit, not just a general processing licence.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

\$ 12

Children's Data

Merged: Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL

Children's data is classified as sensitive and requires verified guardian consent plus enhanced protections. (Egypt PDPL: Art. 15–16 | EU GDPR: Art. 8 | KSA PDPL: PDPL — processing of minors' data | UAE PDPL: Minors' data provisions)

Nearest framework cross-reference: ISO/IEC 27701 — §7.2 (Consent conditions — minors) · NIST Privacy Framework — CT.PO-P (Data Processing Policies)

Q53 (Egypt PDPL Art. 15–16 · EU GDPR Art. 8 · KSA PDPL Minors' data provisions · UAE PDPL Minors' data provisions) — We obtain verified guardian/parental consent before processing a minor's personal data, with additional safeguards applied.

HIGH RISK

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL)

EXAMPLE A youth-oriented app requires verified guardian consent before account creation for underage users.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q54 (Art. 15–16) — We do not use behavioural profiling of children, and games/competitions aimed at minors do not collect more data than strictly

MEDIUM RISK

necessary.

Egypt PDPL-only

EXAMPLE A kids' colouring competition collects a child's name and a parent's email only — not location, device ID, or browsing habits for ad targeting.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

DOMAIN IV

Individual Rights & Transparency

How data subjects exercise their rights, and how clearly they're told what happens to their data.

\$ 13

Data Subject Rights & Transparency

Merged: Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + ISO 27701 + NIST Privacy Framework

Individuals hold rights to access, correct, restrict, object to, and request erasure of their data, and to be notified of breaches affecting them.
(Egypt PDPL: Art. 2, 4, 6–9 | EU GDPR: Art. 12–21 | KSA PDPL: PDPL — data subject rights | UAE PDPL: Art. 13–18 | ISO 27701: ISO/IEC 27701 — §7.3 (Obligations to PII principals) | NIST Privacy Framework: NIST Privacy Framework 1.0 — CM.PO-P / CM.AW-P (Communication Policies & Awareness))

Nearest framework cross-reference: ISO/IEC 27701 — §7.3 (Obligations to PII principals) · NIST Privacy Framework — CM.PO-P / CM.AW-P (Communication Policies & Awareness)

Q55 (Egypt PDPL Art. 2 · EU GDPR Art. 12, 15–18 · KSA PDPL Access/correction/deletion rights · UAE PDPL Art. 13–15 · ISO 27701 §7.3) — We have a working process to handle access, correction, erasure/deletion, and restriction requests within the applicable statutory timeframe.

HIGH RISK

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + ISO 27701)

EXAMPLE A customer's access request is logged, verified, and answered within the required period, with extension notices sent if genuinely complex.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q56 (EU GDPR Art. 20 · KSA PDPL Data portability) — We can provide personal data in a structured, portable format on request.

MEDIUM RISK

✓ Harmonised (EU GDPR + KSA PDPL)

EXAMPLE A user requesting their account data receives a CSV/JSON export, not a screenshot.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q57 (Egypt PDPL Art. 2, 8 · EU GDPR Art. 13–14 · KSA PDPL Transparency provisions · UAE PDPL Art. 18 · NIST Privacy Framework CM.PO-P1) — Our privacy notices clearly explain what data we collect, why, for how long, and who to contact — in the required language(s).

MEDIUM RISK

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + NIST Privacy Framework)

EXAMPLE A non-technical reader can finish the notice and explain, in one sentence, what happens to their data.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q58 (Art. 2, 7) — Data subjects are notified when their data is affected by a breach that risks their rights or interests.

MEDIUM RISK

Egypt PDPL-only

EXAMPLE If a database of customer ID numbers is exposed, affected customers are told directly within days — not left to find out from the news.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q59 (Art. 2, 6) — We verify the identity of anyone requesting access to personal data before releasing it.

MEDIUM RISK

Egypt PDPL-only

EXAMPLE A guest asking for a copy of their booking history first confirms their identity via a one-time code sent to their registered phone or email.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q60 (Art. 4, 9) — We log every rights request — type, date, and outcome, including reasons for any refusal — in a register we could show a regulator.

MEDIUM RISK

Egypt PDPL-only

EXAMPLE An auditor asks 'show me every erasure request from last quarter,' and you can produce a dated list with outcomes and justifications.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q61 (Art. 21) — We honour objections to processing, including an absolute, no-questions-asked right to object to direct marketing.

MEDIUM RISK

EU GDPR-only

EXAMPLE Anyone can stop marketing emails with one click, without justifying why.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q62 (Art. 16–17) — We honour objections to processing and requests to restrict processing.

MEDIUM RISK

UAE PDPL-only

EXAMPLE A customer objecting to profiling for marketing purposes has that processing stopped.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q63 (§7.3) — The organisation can locate personal information relevant to a request across production systems, backups, logs, and third-party processors — not just the primary system of record.

MEDIUM RISK

ISO 27701-only

EXAMPLE An erasure request is checked against backup retention and third-party processor copies, not just the live database.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q64 (CM.AW-P1-P8) — Workforce members understand their role in privacy protection through role-specific awareness activities, not a single generic training module.

MEDIUM RISK

NIST Privacy Framework-only

EXAMPLE Engineering staff receive privacy-by-design guidance specific to their role, distinct from the general workforce privacy-awareness training.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

§ 14

Transparency & Human Oversight

Merged: EU AI Act + ISO 42001

High-risk AI systems must be accompanied by clear instructions for use, and be designed to allow effective human oversight, including the ability to intervene or halt the system. (EU AI Act: Art. 13-14 | ISO 42001: ISO/IEC 42001 — Annex A.9)

Nearest framework cross-reference: ISO/IEC 27701 — §7.3 (loose parallel — obligations to PII principals) · NIST Privacy Framework — NIST AI RMF — GOVERN 4 / MANAGE 4 (human oversight)

Q65 (EU AI Act Art. 14 · ISO 42001 Annex A.9.2) — We can demonstrate effective human oversight of AI systems — a named, trained person can understand, monitor, and actually intervene in or halt the system's operation, not just in theory.

HIGH RISK

✓ Harmonised (EU AI Act + ISO 42001)

EXAMPLE A credit-decision AI has a named reviewer who can override or halt an automated decision, and that capability is periodically tested.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q66 (Art. 13) — High-risk AI systems we deploy come with clear instructions for use covering their capabilities, limitations, and appropriate use context.

MEDIUM RISK

EU AI Act-only

EXAMPLE A diagnostic-support tool's instructions explicitly state its accuracy limitations and the contexts it hasn't been validated for.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q67 (Annex A.9.3) — Users are informed when they interact with an AI system, and are given information about the system's limitations, intended uses, and confidence concerns appropriate to the decision context.

MEDIUM RISK

ISO 42001-only

EXAMPLE

A support chatbot identifies itself as AI and gives users a clear path to a human when the AI's confidence is low.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

\$ 15

Transparency & Content Labeling (Chatbots, Deepfakes, Synthetic Media)

EU AI Act

Providers/deployers of chatbots, emotion-recognition or biometric-categorisation systems, and generative/synthetic-media systems must disclose AI involvement to end users — obligations that took effect 2 August 2026 independent of the high-risk-system timeline delay. (Art. 50)

Nearest framework cross-reference: ISO/IEC 27701 — §7.3 (loose parallel — transparency to individuals) · NIST Privacy Framework — NIST AI RMF — GOVERN 4.2 (transparency policies) · ISO/IEC 42001 — Annex A.9 (transparency); no ISO 27701 equivalent for content labeling specifically

Q68 (Art. 50(1)) — Individuals interacting with a chatbot or conversational AI system are clearly informed they are interacting with AI, unless obviously apparent from context.

HIGH RISK

This obligation is in force from 2 Aug 2026 and was not affected by the Digital Omnibus's high-risk-system delay.

EXAMPLE

A customer-service chatbot identifies itself as AI-powered at the start of the conversation.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q69 (Art. 50(4)) — AI-generated or manipulated image, audio, or video content (synthetic media) we produce or distribute is labelled as AI-generated/manipulated.

HIGH RISK

EXAMPLE

A marketing video using AI-generated voiceover or imagery carries a clear synthetic-content label.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q70 (Art. 50) — We maintain a status dashboard or register tracking which of our systems fall under Article 50 obligations and their current labeling/disclosure coverage.

MEDIUM RISK

EXAMPLE A single register lists every generative or conversational AI touchpoint and confirms disclosure/labeling is live for each.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

DOMAIN V

Third-Party & Cross-Border Risk

Processor obligations and international data transfers.

\$ 16

Cross-Border Transfers

Merged: Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + HIPAA + ISO 27701 + NIST Privacy Framework

Transferring personal data outside Egypt requires equivalent protection at the destination and prior PDPC authorization, absent a recognised exception. (Egypt PDPL: Art. 5, 10–12 | EU GDPR: Art. 28, 44–49 | KSA PDPL: PDPL Art. 29 (cross-border transfer) | UAE PDPL: Art. 22–23 | HIPAA: 45 C.F.R. §§164.502(e), 164.504(e) (Business Associate Agreements) | ISO 27701: ISO/IEC 27701 – §7.5 (Sharing, transfer, disclosure); §8 (Supplier relationships) | NIST Privacy Framework: NIST Privacy Framework 1.0 – ID.DE-P (Data Processing Ecosystem Risk Management))

Nearest framework cross-reference: ISO/IEC 27701 – §7.5 (PII sharing, transfer & disclosure) · NIST Privacy Framework – ID.DE-P (Data Processing Ecosystem Risk Mgmt)

Q71 (Egypt PDPL Art. 10–11 · KSA PDPL Art. 29 · UAE PDPL Art. 22) — We maintain an inventory of all cross-border transfers of personal data, including to cloud/SaaS providers.

MEDIUM RISK

✓ Harmonised (Egypt PDPL + KSA PDPL + UAE PDPL)

EXAMPLE A single list shows which vendors host data outside the jurisdiction and in which country.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q72 (Egypt PDPL Art. 10–12 · EU GDPR Art. 44–46, 49 · KSA PDPL Art. 29 · UAE PDPL Art. 22–23 · ISO 27701 §7.5) —

HIGH RISK

Every cross-border transfer relies on a documented safeguard: destination adequacy, standard contractual clauses, binding rules, certification, or a specific statutory exception.

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + ISO 27701)

EXAMPLE A transfer to an overseas data centre relies on approved contractual clauses, documented as such — not an assumption that 'a big vendor means it's fine.'

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q73 (Egypt PDPL Art. 10 · EU GDPR Art. 44 (Schrems II)) —

MEDIUM RISK

We have assessed whether the destination country's laws undermine the safeguard relied on, and applied supplementary measures where needed.

✓ Harmonised (Egypt PDPL + EU GDPR)

EXAMPLE A Transfer Impact Assessment for a foreign cloud vendor considers government surveillance access and adds encryption with locally-held keys as a supplementary measure.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q74 (Egypt PDPL Art. 5, 11 · EU GDPR Art. 28 · KSA PDPL Processor obligations · UAE PDPL Processor obligations · ISO 27701 §8 · HIPAA §164.502(e)(1), §164.504(e) — Business Associate Agreement) — Contracts with international vendors/processors include the data-protection clauses required for cross-border processing.

MEDIUM RISK

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + ISO 27701 + HIPAA)

EXAMPLE Your contract with an overseas SaaS provider includes clauses on data protection obligations and breach liability, not just service-level terms.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q75 (Art. 10–11 · 2025 Exec. Reg.) — We hold or have applied for the cross-border transfer authorization where required.

HIGH RISK

Egypt PDPL-only

EXAMPLE You've either obtained the authorisation and paid the associated fee, or submitted the application and can show the reference

number.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q76 (\$164.504(e)) — BAAs are tracked centrally (not left to individual departments) and reviewed/renewed on a defined cadence.

MEDIUM RISK

HIPAA-only

EXAMPLE A single register lists every active BAA, its renewal date, and which department owns the relationship, rather than contracts scattered across departmental files.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q77 (ID.DE-P1, ID.DE-P4) — Third parties that process personal data on our behalf are identified, and their privacy risk is assessed and prioritised before onboarding.

HIGH RISK

NIST Privacy Framework-only

EXAMPLE A new vendor handling customer data goes through a privacy risk assessment before the contract is signed, with higher-risk vendors receiving deeper scrutiny.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

\$ 17

Vendor & Third-Party Risk Management

Merged: Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL

Engaging a processor or other third party to handle personal data doesn't transfer away the controller's accountability — vendors must be assessed for risk before onboarding and tracked centrally for the life of the relationship. (Egypt PDPL: Art. 5, 11 · 2025 Exec. Reg. | EU GDPR: GDPR Art. 28 | KSA PDPL: PDPL — processor obligations | UAE PDPL: UAE Federal Decree-Law 45/2021 — processor obligations)

Nearest framework cross-reference: ISO/IEC 27701 — · NIST Privacy Framework — ·

Q78 (Egypt PDPL Art. 5, 11 · EU GDPR Art. 28(1) · KSA PDPL Processor obligations · UAE PDPL Processor obligations) — We assess and risk-tier third-party vendors before onboarding them for any activity involving personal data, with higher-risk vendors receiving deeper scrutiny.

MEDIUM RISK

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL)

EXAMPLE A vendor with broad access to sensitive records goes through a deeper review than one handling low-sensitivity operational data.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q79 (Egypt PDPL Art. 11 · EU GDPR Art. 28(3) · KSA PDPL Processor obligations · UAE PDPL Processor obligations) —

MEDIUM RISK

We maintain a central register of vendor data-protection agreements with renewal dates and a named owner, rather than contracts scattered across departments.

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL)

EXAMPLE A single register lists every active vendor agreement touching personal data, its renewal date, and which department owns the relationship.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

DOMAIN VI

Privacy Incident Management

Breach detection, notification, and post-incident learning.

\$ 18

Breach Notification

Merged: Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + HIPAA + ISO 27701 + NIST Privacy Framework

Qualifying breaches must be reported to the PDPC within 72 hours (immediately for national security incidents), and to affected individuals within 3 days of PDPC notification. (Egypt PDPL: Art. 2, 4, 6-7 | EU GDPR: Art. 33-34 | KSA PDPL: PDPL — breach notification provisions | UAE PDPL: Art. 9 | HIPAA: 45 C.F.R. §§164.400-414 (Breach Notification Rule) | ISO 27701: ISO/IEC 27701 — §6.13 (Incident management, extends ISO 27001 A.16) | NIST Privacy Framework: NIST Privacy Framework 1.0 — PR.PO-P (Protect — Policies) / RS (Respond))

Nearest framework cross-reference: ISO/IEC 27701 — §6.13 (Incident management, extends ISO 27001 A.16) · NIST Privacy Framework — PR.PO-P (Protect — Policies) / RS (Respond)

Q80 (Egypt PDPL Art. 7 · EU GDPR Art. 33 · KSA PDPL 72-hour standard · UAE PDPL Art. 9 (without undue delay) · ISO 27701 §6.13) —

HIGH RISK

We have a documented incident response plan able to assess and notify the relevant regulator of a breach within the required timeframe (commonly 72 hours).

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + ISO 27701)

EXAMPLE A stolen laptop with a customer export triggers an assessment and a regulator filing inside the required window.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q81 (Egypt PDPL Art. 2, 7 · EU GDPR Art. 34 · KSA PDPL Data subject breach notification · UAE PDPL Art. 9) —

HIGH RISK

Where a breach poses a risk to affected individuals, we notify them directly without undue delay.

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL)

EXAMPLE Customers whose payment data was exposed are notified promptly with concrete protective steps.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q82 (Egypt PDPL Art. 4, 7 · EU GDPR Art. 33(5) · KSA PDPL Breach recordkeeping · UAE PDPL Breach recordkeeping · ISO 27701 §6.13, 10.2) —

MEDIUM RISK

We maintain a register of every personal data breach — cause, data affected, and remedial action — regardless of whether it required notification.

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + ISO 27701)

EXAMPLE A minor, contained incident is still logged with cause and resolution, not just the major ones.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q83 (Art. 6, 7) —

MEDIUM RISK

We have run or tested this breach response process at least once in the past 12 months.

Egypt PDPL-only

EXAMPLE You've run a tabletop exercise or handled a real incident in the past year and can point to what changed afterward.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q84 (§164.402, §164.404) —

HIGH RISK

We have a documented process to assess whether an incident involving PHI meets HIPAA's definition of a

reportable breach, including the required risk assessment factors.

HIPAA-only

EXAMPLE An incident involving misdirected patient records goes through a documented four-factor risk assessment before a reportable/non-reportable determination is made, rather than an ad hoc judgment call.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q85 (§164.404, §164.408, §164.406) — We can notify affected individuals within 60 days of discovery, and separately notify HHS (with Media notification for breaches affecting 500+ individuals in one jurisdiction).

HIGH RISK

HIPAA-only

EXAMPLE A breach affecting 600 patients in one state triggers individual letters, an HHS filing, and a media notice — all within their respective required windows, not just the individual letters.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q86 (PR.PO-P, RS.RP-P) — A documented privacy incident response process exists, is periodically exercised (tabletop or similar), and assigns clear ownership.

HIGH RISK

NIST Privacy Framework-only

EXAMPLE The incident response plan was actually run through a tabletop exercise in the last year, with lessons captured, rather than existing only as an untested document.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

DOMAIN VII

Security, Privacy by Design & Assurance

Technical/organisational safeguards, DPIAs, and physical monitoring (CCTV).

Contracts & Impact Assessments

Controllers and processors must implement technical/organisational safeguards, and processors must act only on documented instructions.
(Egypt PDPL: Art. 3, 5-6 | EU GDPR: Art. 25, 32, 35 | KSA PDPL: PDPL – technical & organisational security measures | UAE PDPL: Technical & organisational security provisions | HIPAA: 45 C.F.R. §164.312 (Technical Safeguards), §164.310 (Physical Safeguards) | ISO 27701: ISO/IEC 27701 – Clause 6 (extends ISO 27001 Annex A controls) | NIST Privacy Framework: NIST Privacy Framework 1.0 – PR.DS-P (Protect – Data Security))

Nearest framework cross-reference: ISO/IEC 27701 – Clause 6 (Info security controls) & §7.4 (Privacy by design) · NIST Privacy Framework – PR.DS-P (Protect – Data Security)

Q87 (Egypt PDPL Art. 6 · EU GDPR Art. 32 · KSA PDPL Security measures · UAE PDPL Security measures · ISO 27701 Clause 6 · HIPAA §164.312(a)(2)(iv), §164.312(e)(2)(ii) · NIST Privacy Framework PR.DS-P1) — We apply technical and organisational security measures (encryption, access controls) proportionate to the sensitivity of data held. HIGH RISK

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + ISO 27701 + HIPAA + NIST Privacy Framework)

EXAMPLE Customer payment and health data are encrypted at rest and in transit, with access limited to specific roles.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q88 (Egypt PDPL Art. 6 · 2025 Exec. Reg. · EU GDPR Art. 35 · KSA PDPL Risk assessment expectations · UAE PDPL Risk assessment expectations) — We conduct a data protection / risk impact assessment before launching high-risk processing. HIGH RISK

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL)

EXAMPLE Before rolling out a new profiling or analytics feature, someone completed and documented a formal risk assessment.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q89 (Egypt PDPL Art. 3, 6 · EU GDPR Art. 25) — We apply privacy by design and by default when building new products, systems, or services. MEDIUM RISK

✓ Harmonised (Egypt PDPL + EU GDPR)

EXAMPLE A new app defaults location-sharing to off, requiring active opt-in to enable it.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q90 (Egypt PDPL Art. 6 · KSA PDPL Personnel obligations · UAE PDPL Personnel obligations) — Employees who handle personal data are bound by confidentiality obligations and trained on current requirements.

LOW RISK

✓ Harmonised (Egypt PDPL + KSA PDPL + UAE PDPL)

EXAMPLE Staff have signed confidentiality undertakings and completed refresher training in the last year.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q91 (Art. 5) — Contracts with external processors define their security obligations and liability for breaches.

MEDIUM RISK

Egypt PDPL-only

EXAMPLE Your contract with an outsourced call centre or IT vendor says who's responsible, and for what, if customer data they handle is leaked.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q92 (Art. 5) — Our processors act only on our documented instructions and don't process personal data for their own separate purposes.

LOW RISK

Egypt PDPL-only

EXAMPLE An outsourced marketing agency uses your customer list only for the campaign you commissioned, not to build its own prospect database.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q93 (Art. 5) — Processors delete or return all personal data to us once processing ends or the contract terminates.

MEDIUM RISK

Egypt PDPL-only

EXAMPLE When you switch CRM providers, the outgoing vendor confirms in writing that your customer data has been deleted or returned, not retained.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q94 (§164.312 (a) (2) (i) , §164.308 (a) (4)) — Every workforce member with system access to ePHI has a unique user ID — no shared or generic logins — and access is limited to what their role requires.

HIGH RISK

HIPAA-only

EXAMPLE A nurse's login is traceable to that individual specifically, and their access is scoped to the patients/records their role covers, not the entire system.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q95 (§164.310 (a) (1)) — Physical access to locations and devices where ePHI is stored or accessed is controlled and monitored.

MEDIUM RISK

HIPAA-only

EXAMPLE A server room or records archive requires badge access and logs entries, rather than an unlocked door.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q96 (§164.312 (b)) — Audit logs capture access to ePHI systems and are actually reviewed, not just collected.

MEDIUM RISK

HIPAA-only

EXAMPLE Someone periodically reviews access logs for a patient records system and can point to what they checked, not just confirm logging is technically enabled.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q97 (Clause 6) — Privacy risk management is integrated with the organisation's broader information-security risk management, rather than run as a separate, disconnected process.

MEDIUM RISK

ISO 27701-only

EXAMPLE The privacy risk register and the security risk register reference each other where a risk touches both domains, rather than duplicating or contradicting each other.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

§ 20

Visual Surveillance (CCTV) & Public Monitoring

Merged: Egypt PDPL + EU GDPR

The 2025 Executive Regulations introduce licensing for CCTV systems covering public or common areas — a distinctive feature of the Egyptian regime, especially relevant for retail, hospitality, and mixed-use developments. (Egypt PDPL: Art. 3, 6, 13-14, 19-21 · 2025 Exec. Reg. | EU GDPR: Art. 5, 6, 35 (via EDPB video-surveillance guidance))

Nearest framework cross-reference: ISO/IEC 27701 — §7.4 (Privacy by design/default — new technology risk) · NIST Privacy Framework — ID.RA-P (Risk Assessment)

Q98 (Egypt PDPL Art. 3 · 2025 Exec. Reg. · EU GDPR Art. 5, 13 (EDPB Guidelines 3/2019)) — CCTV/video monitoring is proportionate to a documented purpose (e.g. security), with any other use requiring a separate basis.

MEDIUM RISK

✓ Harmonised (Egypt PDPL + EU GDPR)

EXAMPLE Footage used to investigate a theft is fine; footage repurposed to analyse foot-traffic for marketing is not, without a fresh basis.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q99 (Egypt PDPL Art. 13-14 · 2025 Exec. Reg. · EU GDPR Art. 9, 35) — We do not use facial recognition on CCTV footage without specific legal authorisation or explicit consent.

MEDIUM RISK

✓ Harmonised (Egypt PDPL + EU GDPR)

EXAMPLE Cameras deter and record incidents but don't automatically match faces against a database.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q100 (2025 Exec. Reg.) — We know how many cameras we operate in public or common areas, and treat that count as a licensing trigger.

LOW RISK

Egypt PDPL-only

EXAMPLE Cameras covering a shopping mall atrium or a shared walkway are counted separately from cameras inside a private office.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q101 (2025 Exec. Reg.) — Camera coverage is limited so that private-area systems don't spill into common areas in a way that would require licensing.

LOW RISK

Egypt PDPL-only

EXAMPLE A front-door camera is angled to capture only its own doorstep, not the shared street or corridor beyond it.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q102 (Art. 19–21 · 2025 Exec. Reg.) — We have applied for, or confirmed we don't need, the visual surveillance permit for cameras covering public spaces.

HIGH RISK

Egypt PDPL-only

EXAMPLE You can produce a permit reference for the cameras in a public plaza or lobby, not just an assumption that 'security cameras are fine.'

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q103 (Art. 6) — CCTV footage is stored securely — encrypted where appropriate — with access limited to specific, logged roles.

HIGH RISK

Egypt PDPL-only

EXAMPLE Only two named security staff can pull footage, and every access is logged, rather than a shared login anyone on site can use.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

All workforce members with access to PHI must receive periodic security awareness and privacy training, tracked and documented — not a one-time onboarding exercise. (45 C.F.R. §164.308(a)(5) (Security Awareness & Training))

Nearest framework cross-reference: ISO/IEC 27701 — — · NIST Privacy Framework — —

Q104 (§164.308(a)(5)(i)) — All workforce members with access to PHI complete HIPAA training at onboarding and on a recurring basis (commonly annually), with completion tracked per individual. HIGH RISK

EXAMPLE A training-completion dashboard shows which staff are current and which are overdue, by name — not an assumption that 'everyone did the onboarding module once'.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q105 (§164.308(a)(5)(ii)) — Training content is updated when policies, systems, or known threats change materially, not left static year over year. LOW RISK

EXAMPLE Training content was updated after a recent phishing-related incident to cover that specific risk, rather than using the same slide deck for several years running.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

DOMAIN VIII

Direct Marketing & Communications

Consent-based marketing and tracking-technology governance.

§ 22

Direct Electronic Marketing

Merged: Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL + ISO 27701

Electronic marketing requires opt-in consent, a clear unsubscribe mechanism, and consent records. (Egypt PDPL: Art. 4, 8, 17-18 | EU GDPR: ePrivacy Directive (as implemented nationally) + GDPR Art. 6/7/21 | KSA PDPL: PDPL — consent-based marketing (general principles) | UAE PDPL: Consent-based marketing provisions | ISO 27701: ISO/IEC 27701 — §7.3.7 (Marketing-related obligations))

Nearest framework cross-reference: ISO/IEC 27701 — §7.3.7 (Marketing consent/opt-out obligations) · NIST Privacy Framework — CT.PO-P (Data Processing Policies)

Q106 (Egypt PDPL Art. 17–18 · EU GDPR ePrivacy Directive; Art. 21 · KSA PDPL Consent & marketing · UAE PDPL Consent & marketing) — We only send direct electronic marketing to individuals who have consented, with a clear, simple opt-out in every message.

MEDIUM RISK

✓ Harmonised (Egypt PDPL + EU GDPR + KSA PDPL + UAE PDPL)

EXAMPLE A promotional message includes a one-tap way to stop future communications.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q107 (Egypt PDPL Art. 4, 17–18 · EU GDPR ePrivacy Directive; Art. 7) — Website tracking technologies (cookies, analytics, ad pixels) run through a consent mechanism, not by default.

MEDIUM RISK

✓ Harmonised (Egypt PDPL + EU GDPR)

EXAMPLE A first-time visitor sees a cookie banner and analytics scripts don't fire until they choose to accept.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q108 (Art. 17–18) — We keep records of marketing consent (or non-objection) as required.

LOW RISK

Egypt PDPL-only

EXAMPLE For any name on your marketing list today, you can show when and how they opted in.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q109 (Art. 17–18) — An opt-out or unsubscribe updates one central "Do Not Contact" list used across every team and channel.

MEDIUM RISK

Egypt PDPL-only

EXAMPLE Someone who unsubscribes from email marketing also stops receiving SMS and WhatsApp campaigns from the same organisation.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q110 (Art. 8, 17–18) — Every marketing message clearly identifies the sending organisation and a real contact for privacy queries.

LOW RISK

Egypt PDPL-only

EXAMPLE A marketing email footer names the company and gives a working contact for data protection questions, not just a no-reply address.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q111 (§9.2 (via ISO 27001 alignment)) — Internal audits of the PIMS are conducted by competent, sufficiently independent auditors, with higher-risk processing activities prioritised for review.

MEDIUM RISK

ISO 27701-only

EXAMPLE An internal audit schedule specifically calls out high-risk processing (e.g. large-scale profiling) for more frequent review than low-risk activities.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q112 (§9.3 (via ISO 27001 alignment)) — Privacy performance indicators (complaints, rights requests, incidents, assessment completion, training completion, supplier performance) are defined, monitored, and reviewed by management at planned intervals.

MEDIUM RISK

ISO 27701-only

EXAMPLE A quarterly management review looks at DSR response times, incident counts, and training completion rates as tracked metrics, not anecdotal impressions.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Product-safety-style obligations for AI systems — prohibited practices, risk/quality management, and conformity readiness — distinct in kind from data-protection law.

§ 23

Prohibited Practices Screening

EU AI Act

Certain AI practices are banned outright regardless of risk-tiering — subliminal manipulation, exploitation of vulnerabilities, social scoring, and most real-time remote biometric identification in public spaces for law enforcement. (Art. 5)

Nearest framework cross-reference: ISO/IEC 27701 — Not applicable — outside PIMS scope · NIST Privacy Framework — NIST AI RMF — GOVERN 1.1 (legal/regulatory requirements mapped) · ISO/IEC 42001 — Clause 4.1 (context) & Annex A.2 (AI policy) — no direct ISO 27701 equivalent

Q113 (Art. 5) — We have screened our AI systems and use cases against the Article 5 prohibited-practice list and confirmed none apply.

HIGH RISK

This is a binary compliance gate, not a risk-tier judgment call — a prohibited practice cannot be mitigated down to an acceptable tier.

EXAMPLE A customer-engagement AI is checked to confirm it doesn't use subliminal techniques or exploit vulnerabilities of specific groups (age, disability) to materially distort behaviour.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q114 (Art. 5, 99) — We have a defined escalation process if a prohibited-practice risk is identified in an existing or proposed AI system.

HIGH RISK

Penalties for prohibited practices are the Act's highest tier (up to €35M or 7% of global turnover).

EXAMPLE A flagged use case is immediately escalated to legal/compliance before further development or deployment continues.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

§ 24

Risk & Quality Management System

Merged: EU AI Act + ISO 42001

Providers of high-risk AI systems must maintain a continuous risk-management system across the system's lifecycle, and a quality management system covering the organisation's overall AI development process. (EU AI Act: Art. 9, 17 | ISO 42001: ISO/IEC 42001 — Clause 6.1, Annex A.3, Clause 8)

Nearest framework cross-reference: ISO/IEC 27701 — Not applicable — outside PIMS scope · NIST Privacy Framework — NIST AI RMF — MEASURE / MANAGE functions

Q115 (EU AI Act Art. 9 · ISO 42001 Clause 6.1, Annex A.3) — We maintain a documented, continuous AI risk-management process, updated across each system's lifecycle rather than assessed once at launch.

HIGH RISK

✓ Harmonised (EU AI Act + ISO 42001)

EXAMPLE A risk log for a credit-scoring model is revisited on every material update, not just at initial deployment.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q116 (EU AI Act Art. 17 (QMS) · ISO 42001 Clause 6.1, 8.2) — Risk acceptance criteria and approval authorities are defined for AI systems, with assessments refreshed after significant changes, incidents, drift, or new use cases.

MEDIUM RISK

✓ Harmonised (EU AI Act + ISO 42001)

EXAMPLE A model that starts being used for a new purpose triggers a fresh risk assessment rather than relying on the original launch assessment indefinitely.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

\$ 25

General-Purpose AI (GPAI) Provider Obligations

Merged: EU AI Act + ISO 42001

Organisations that build or substantially fine-tune general-purpose AI models — not just deploy third-party models — face distinct provider-level obligations, with additional requirements for models presenting systemic risk. (EU AI Act: Art. 53, 55 | ISO 42001: ISO/IEC 42001 — Clause 8.1, Annex A.10 (third-party/customer relationships))

Nearest framework cross-reference: ISO/IEC 27701 — Not applicable — outside PIMS scope · NIST Privacy Framework — NIST AI RMF — MAP 1 / GOVERN 1 (foundation-model-specific guidance still emerging)

Q117 (Art. 53) — If we build or substantially fine-tune a general-purpose AI model, we maintain technical documentation and a copyright/training-content policy as required of GPAI providers.

HIGH RISK

EU AI Act-only

Fine-tuning a third-party model can itself trigger GPAI provider obligations — confirm whether your use case crosses that line before assuming you're only a 'deployer.'

EXAMPLE A team that fine-tunes an open-weight model on proprietary data maintains documentation of the training process and a policy on copyrighted training content, not just downstream usage terms.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q118 (Art. 55) — If our GPAI model presents systemic risk (very high compute / broad downstream reach), we have assessed and documented against the additional systemic-risk obligations.

MEDIUM RISK

EU AI Act-only

This applies to a small number of very large models — most organisations will correctly assess this as not applicable, but the assessment itself should be documented.

EXAMPLE A model-development team documents why their model falls below the systemic-risk compute threshold, rather than leaving the question unaddressed.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q119 (Annex A.10) — Third-party AI models and datasets are assessed for provenance, limitations, bias, security, and licensing before adoption, with supplier roles (provider, deployer, or another role) clearly defined.

HIGH RISK

ISO 42001-only

EXAMPLE Before adopting a third-party model API, someone checks its training-data provenance and licensing terms, not just its API documentation and pricing.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q120 (Annex A.10) — Contracts with AI suppliers address confidentiality, security, sub-processor use, data use, retention, deletion, audit rights, incident cooperation, and — where applicable — model update/deprecation notice.

MEDIUM RISK

ISO 42001-only

EXAMPLE A contract with an AI platform vendor specifies what happens to your data if the vendor updates or deprecates the underlying model.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

\$ 26

Conformity Assessment & CE Marking Readiness

Merged: EU AI Act + ISO 42001

High-risk AI systems require a conformity assessment (self-assessment or third-party, depending on category) and CE marking before market placement, plus an EU declaration of conformity. (EU AI Act: Art. 43, 47 | ISO 42001: ISO/IEC 42001 — Clause 9

(Performance evaluation), Clause 10 (Improvement))

Nearest framework cross-reference: ISO/IEC 27701 – Not applicable – outside PIMS scope · NIST Privacy Framework – Not applicable – conformity assessment is outside NIST AI RMF's voluntary-framework scope

Q121 (Art. 43) — We have identified the correct conformity assessment route (internal control vs. notified-body assessment) for each high-risk AI system we provide.

MEDIUM RISK

EU AI Act-only

EXAMPLE

A biometric-categorisation system correctly identifies that it requires notified-body involvement, rather than defaulting to self-assessment.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q122 (Art. 47, 48) — We maintain a signed EU declaration of conformity and CE marking documentation for each high-risk AI system placed on the market.

MEDIUM RISK

EU AI Act-only

EXAMPLE

Each high-risk system has a corresponding declaration of conformity on file, referencing the specific technical documentation it was assessed against.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q123 (Clause 9.1) — Post-deployment performance and impact of AI systems are monitored, with model or system drift detected and investigated when it occurs.

HIGH RISK

ISO 42001-only

EXAMPLE

A deployed model's accuracy and fairness metrics are tracked over time, and a material drift triggers investigation rather than going unnoticed until a complaint.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q124 (Clause 9.2–9.3) — Internal audits of the AIMS are conducted by competent, sufficiently independent auditors, and management reviews consider changes in law, technology, incidents, complaints, audit results, and AI performance at planned intervals.

MEDIUM RISK

ISO 42001-only

EXAMPLE A quarterly AIMS management review looks at drift incidents, audit findings, and regulatory changes as a standing agenda item.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Q125 (Clause 10.1–10.2) — Nonconformities are documented with root cause, corrective action, owner, and deadline, with effectiveness reviewed — and continual improvement is demonstrated through completed actions, not just identified findings.

MEDIUM RISK

ISO 42001-only

EXAMPLE A finding from last year's audit has a documented corrective action that was actually completed and verified, not left open indefinitely.

Yes — in place

Partially

No

Not applicable

EVIDENCE / COMMENTS (OPTIONAL — INCLUDED IN THE FINAL REPORT)

e.g. reference a policy document, system name, named owner, or note why this is partial/not applicable...

Scoring method:

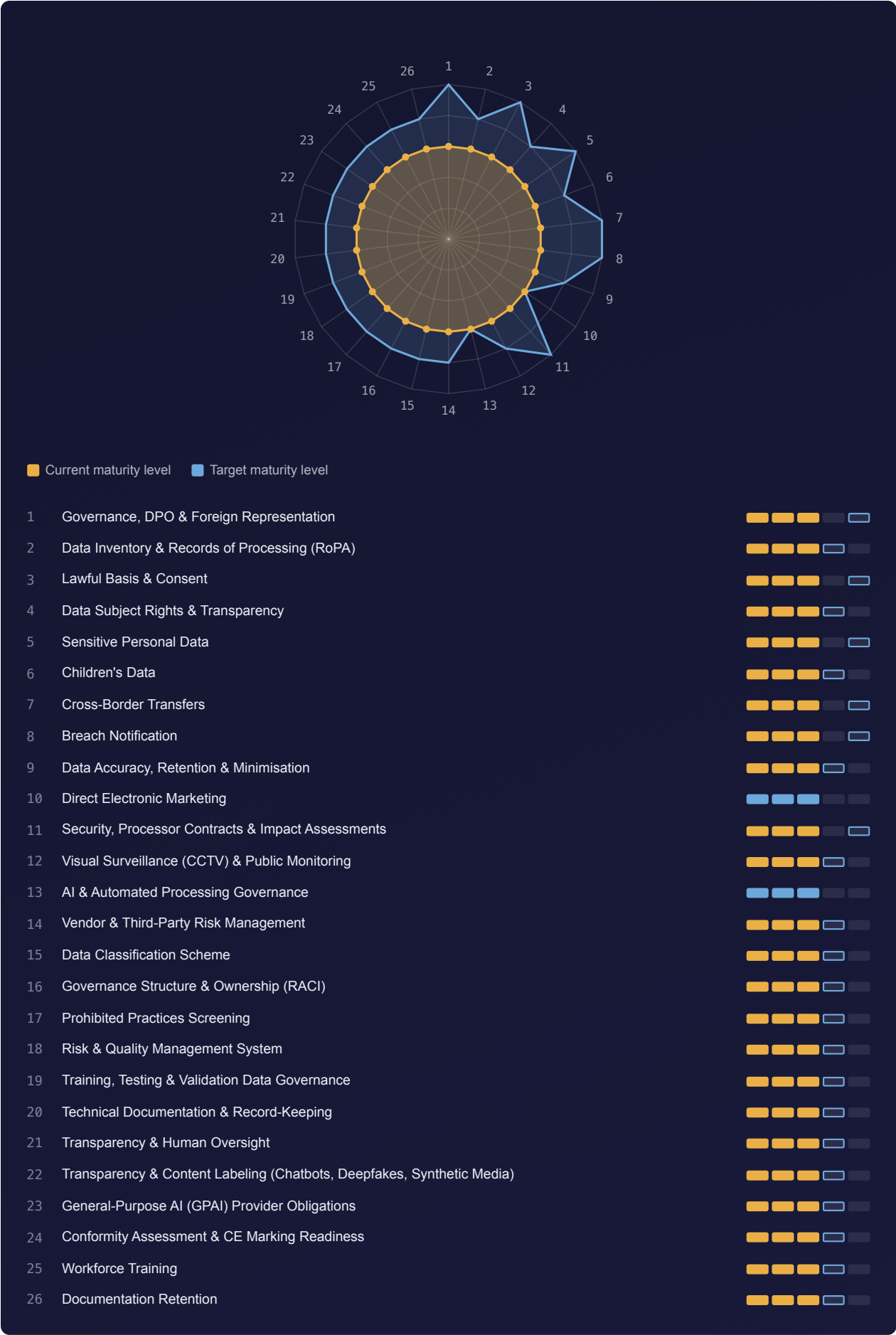
☒ Risk-weighted (recommended — weights each question by regulatory risk)

☐ Simple (every question counts equally)



Overall standing: Emerging (50%)

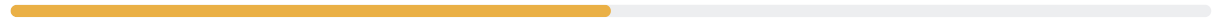
Foundational work has started, but material exposure remains across several articles of the law. (risk-weighted score)



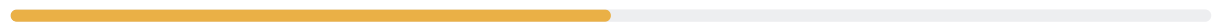
Standing by article

Governance, DPO & Foreign Representation

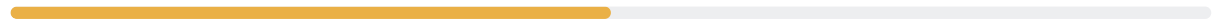
EMERGING · 50%

**Data Inventory & Records of Processing (RoPA)**

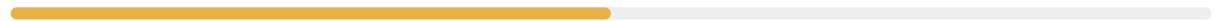
EMERGING · 50%

**Lawful Basis & Consent**

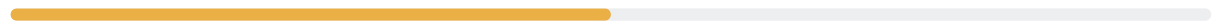
EMERGING · 50%

**Data Subject Rights & Transparency**

EMERGING · 50%

**Sensitive Personal Data**

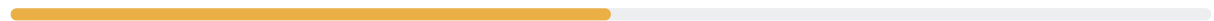
EMERGING · 50%

**Children's Data**

EMERGING · 50%

**Cross-Border Transfers**

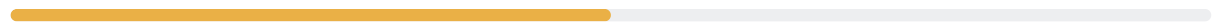
EMERGING · 50%

**Breach Notification**

EMERGING · 50%

**Data Accuracy, Retention & Minimisation**

EMERGING · 50%

**Direct Electronic Marketing**

EMERGING · 50%

**Security, Processor Contracts & Impact Assessments**

EMERGING · 50%

**Visual Surveillance (CCTV) & Public Monitoring**

EMERGING · 50%

**AI & Automated Processing Governance**

EMERGING · 50%

**Vendor & Third-Party Risk Management**

EMERGING · 50%

**Data Classification Scheme**

EMERGING · 50%

**Governance Structure & Ownership (RACI)**

EMERGING · 50%



Prohibited Practices Screening	EMERGING · 50%
Risk & Quality Management System	EMERGING · 50%
Training, Testing & Validation Data Governance	EMERGING · 50%
Technical Documentation & Record-Keeping	EMERGING · 50%
Transparency & Human Oversight	EMERGING · 50%
Transparency & Content Labeling (Chatbots, Deepfakes, Synthetic Media)	EMERGING · 50%
General-Purpose AI (GPAI) Provider Obligations	EMERGING · 50%
Conformity Assessment & CE Marking Readiness	EMERGING · 50%
Workforce Training	EMERGING · 50%
Documentation Retention	EMERGING · 50%

Priority recommendations

- Governance, DPO & Foreign Representation — 50%**

Appoint (or formally engage) a qualified, conflict-free DPO or local representative now, and start the PDPC licence application — the portal and 1 Nov 2026 deadline are approaching.
- Data Inventory & Records of Processing (RoPA) — 50%**

Build a single Record of Processing Activities covering every department, system, and storage location — this underpins almost every other PDPC obligation, including fee tiers.
- Lawful Basis & Consent — 50%**

Formalise a consent capture flow that is specific, evidenced, and separate from general terms of use — and make withdrawal a one-step action.
- Data Subject Rights & Transparency — 50%**

Stand up a single intake channel and SLA for access, correction, objection, and erasure requests, with identity verification and logging so you can demonstrate response times.

Recommended next steps: DPIA / ROPA / DSAR

Shown only for the areas where this assessment found a gap — advisory guidance, not a live workflow. This tool assesses whether these processes exist; it doesn't run them.

DPIA — Data Protection Impact Assessments — related category at 50%

Move from an ad hoc judgment call to a documented threshold-screening step: before any new or materially changed processing activity goes live, run it through a short set of trigger questions — does it involve systematic profiling, special-category data at scale, novel technology, vulnerable individuals (e.g. minors, employees), or matched/combined datasets? Any "yes" should route to a full impact assessment with a named reviewer and a documented Sufficient/Insufficient/Conditional determination, not an informal sign-off. Wire this screening step into whatever change-management or product-launch process already exists, rather than running it as a separate, easily-skipped exercise.

ROPA — Record of Processing Activities — related category at 50%

A spreadsheet someone updates occasionally isn't a Record of Processing Activities — structure it as a proper register with one row per processing activity, not per system, capturing: the controller and any processor(s) involved, the specific purpose, the categories of data and data subjects, retention period, and any third-country transfer with its safeguard. Assign a named owner for keeping it current, and review it on a fixed cadence (e.g. quarterly) rather than only when a regulator or client asks for it. This register is also what a DPIA threshold-screening step and a DSAR intake process both end up depending on, so getting its structure right pays off twice.

DSAR — Data Subject Access Requests — related category at 50%

Replace informal, inbox-based handling with a defined intake-to-fulfillment path: (1) intake through a single identifiable channel, (2) identity verification proportionate to the sensitivity of the data requested, (3) scope assessment — confirming what's actually being asked for and which systems hold it, referencing your data inventory rather than searching from scratch each time, and (4) fulfillment and a closed-out audit log, within the statutory window for whichever framework applies. Track requests centrally so you can demonstrate response-time compliance on demand, not reconstruct it after the fact when asked.



Prepared by Fixed Solutions Group as an independent self-assessment tool based on Law No. 151 of 2020 (Personal Data Protection Law) and Executive Regulations issued under Ministerial Decree No. 816/2025, effective 2 November 2025. Provisions summarised for self-assessment purposes; consult the official Arabic text and qualified counsel for binding interpretation. Not affiliated with the Personal Data Protection Center. **Also covers, where selected:** EU GDPR, Saudi Arabia PDPL, UAE Federal PDPL, EU AI Act, HIPAA (US healthcare), and the voluntary ISO/IEC 27701, ISO/IEC 42001, and NIST Privacy Framework 1.0 standards — see the framework selector above for citations. Same disclaimer applies to all: directional self-assessment only, not legal advice.

Tool version 2.14